

VEILLE TECHNOLOGIQUE

BTS SIO – Option SISR | Année scolaire 2024–2026

THÈME

Les attaques DDoS : un défi majeur pour la cybersécurité des infrastructures réseau

Candidat	Wesley AMAVI
Classe	BTS SIO SISR – 2ème année
Établissement	INSTA
Année scolaire	2024 – 2026

Introduction & Contexte

1.1 Définition et contexte des attaques DDoS

Les attaques DDoS (Distributed Denial of Service – Déni de Service Distribué) constituent aujourd'hui l'une des menaces les plus redoutables pour les infrastructures réseau mondiales. Leur principe est simple mais dévastateur : rendre un service, un site web ou une application totalement indisponible en le submergeant de requêtes malveillantes provenant de milliers, voire de millions, de sources simultanées.

En 2025 et 2026, ces attaques ont franchi de nouveaux records de puissance et de sophistication. Cloudflare a enregistré en janvier 2025 une attaque dépassant les 5,6 Tbps (térabits par seconde), surpassant tous les précédents records historiques. L'intelligence artificielle, l'explosion de l'IoT (Internet des Objets) et la démocratisation des outils d'attaque sur le dark web font de cette menace un problème permanent et évolutif.

Chiffre clé 2025–2026

Augmentation de 137 % des attaques DDoS en Europe en 2025 (Rapport Link11 Cybersecurity 2025). En 2026, le coût moyen d'une attaque DDoS pour une entreprise est estimé entre 20 000 et 40 000 euros par heure d'indisponibilité.

1.2 Enjeux pour l'étudiant SISR

En tant que futur technicien en Solutions d'Infrastructure, Systèmes et Réseaux, la compréhension des attaques DDoS est fondamentale. Le technicien SISR est en première ligne pour :

- Configurer et maintenir les équipements de protection réseau (pare-feu, IDS/IPS)
- Mettre en place des outils de surveillance et de détection d'anomalies
- Intervenir rapidement lors d'incidents de sécurité

- Proposer et implémenter des plans de continuité d'activité

1.3 Problématique

Problématique centrale

Comment les attaques DDoS évoluent-elles à l'ère de l'IA et de l'IoT, et quelles stratégies un technicien SISR peut-il mettre en oeuvre pour protéger efficacement les infrastructures réseau en 2026 ?

1. État des lieux – Botnets & Saturation IoT

1.1 Mécanisme technique : Botnets et IoT

Une attaque DDoS repose sur le contrôle d'un réseau massif de machines compromises, appelé botnet. L'attaquant (le « bot-herder ») prend le contrôle de ces machines à l'insu de leurs propriétaires, via des malwares, des failles de sécurité ou des équipements IoT mal sécurisés, puis les dirige simultanément contre une cible unique.

Avec l'explosion de l'IoT (caméras IP, routeurs domestiques, objets connectés), les botnets atteignent désormais des tailles inégalées. Le botnet Mirai et ses dérivés (Moobot, Zerobot) continuent d'évoluer en 2025–2026 et constituent une menace permanente.

Focus technique – Anatomie d'une attaque DDoS (4 étapes)

1. Infection : L'attaquant compromet des milliers de machines (PC, caméras, routeurs IoT)
2. Constitution du botnet : Les machines infectées reçoivent des instructions via un serveur C&C (Command & Control)
3. Déclenchement : À l'ordre de l'attaquant, toutes les machines bombardent simultanément la cible
4. Saturation : Le serveur cible ne peut plus traiter les requêtes légitimes → indisponibilité totale

1.2 Impact 5G et botnets de nouvelle génération

L'avènement de la 5G amplifie considérablement la menace. La 5G multiplie par 10 à 100 les débits disponibles pour les appareils connectés, permettant à un botnet IoT de générer des volumes d'attaque sans précédent. Les botnets de 5ème génération exploitent des millions de capteurs industriels, de caméras de vidéosurveillance et d'équipements domotiques connectés en permanence via des liaisons très haut débit.

Cette évolution impose au technicien SISR de repenser les seuils de détection et de dimensionner les solutions de protection pour absorber des attaques dépassant le Tbps depuis des sources géographiquement dispersées.

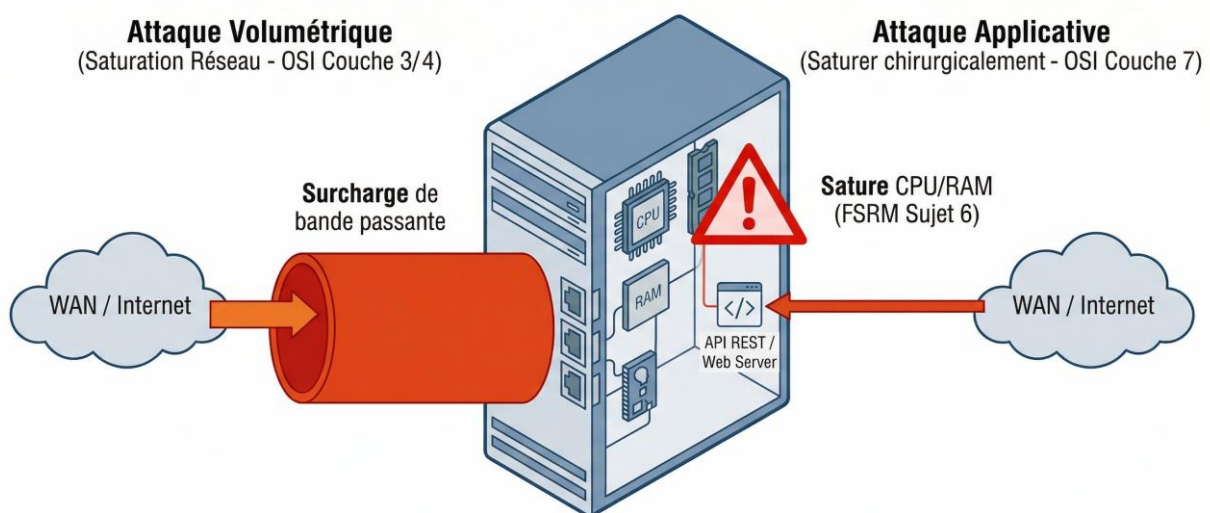


Figure 1 : Architecture d'un Botnet DDoS piloté par C&C (Command & Control), exploitant la vulnérabilité des parcs IoT massifs connectés en 5G, une menace critique identifiée pour 2026.

2. Typologies avancées des attaques DDoS

2.1 Classification par couche OSI

On distingue trois grandes catégories d'attaques DDoS, selon la couche réseau ciblée. Cette classification est essentielle pour le technicien SISR, car chaque type d'attaque requiert des contre-mesures différentes :

Type	Couche OSI	Méthode	Exemples	Impact
Volumétrique	Couche 3-4	Saturation bande passante	UDP Flood, DNS Amplification, ICMP Flood	Réseau saturé
Protocolaire	Couche 4	Exploitation protocoles TCP/IP	SYN Flood, ACK Flood, Ping of Death	Serveur saturé
Applicative	Couche 7	Requêtes HTTP légitimes en masse	HTTP GET/POST Flood, Slowloris	Application hors ligne

2.2 Zoom Couche 7 – Attaques applicatives sur API REST

Les attaques applicatives (couche 7) sont les plus sophistiquées et les plus difficiles à contrer. Contrairement aux attaques volumétriques détectables par leur volume brut de trafic, les attaques applicatives génèrent des requêtes qui semblent totalement légitimes pour les équipements réseau intermédiaires.

L'attaque HTTP Flood consiste à envoyer massivement des requêtes GET ou POST valides vers un serveur web ou une API REST. Chaque requête nécessite un traitement applicatif complet, consommant CPU et RAM jusqu'à épuisement total des ressources. Slowloris maintient des milliers de connexions HTTP semi-ouvertes pour bloquer les slots disponibles.

Les attaques DDoS assistées par l'IA (tendance 2025–2026) génèrent des attaques adaptatives qui analysent les défenses en temps réel et modifient leur comportement pour contourner les règles de filtrage statiques.

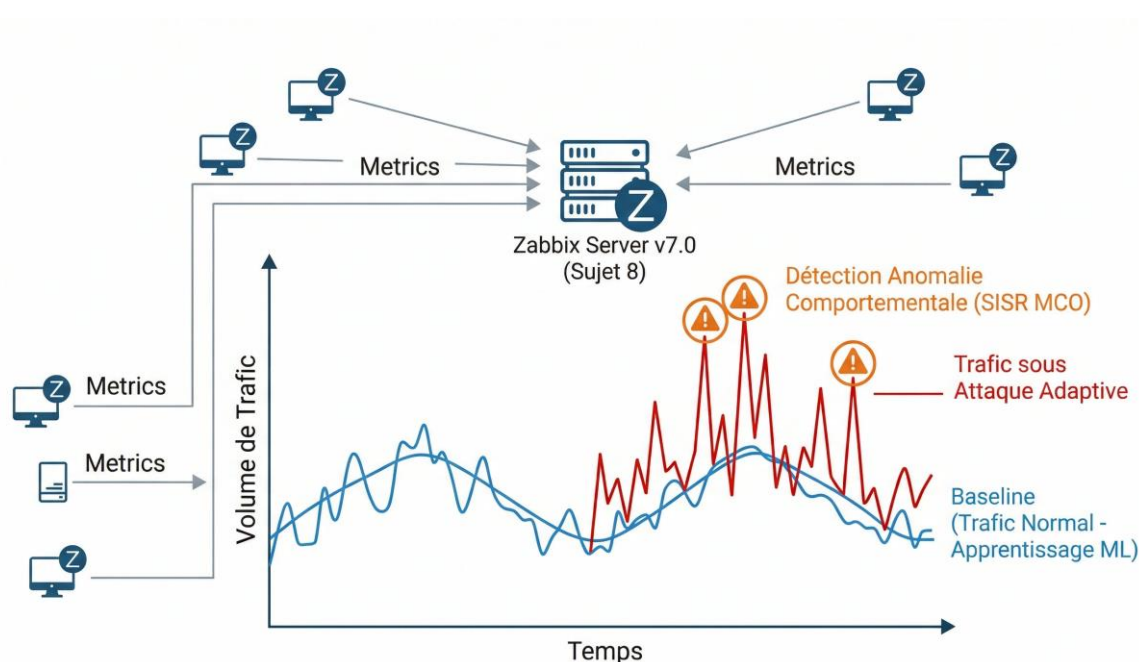


Figure 2 : Analyse comparative des vecteurs d'attaque DDoS : saturation volumétrique des liens réseaux (Couche OSI 3/4) vs saturation applicative chirurgicale (Couche 7 ciblant une API REST).

3. Stratégies de défense contre les DDoS

3.1 Détection comportementale et Machine Learning

La protection contre les attaques DDoS repose désormais sur une approche multicouche combinant des solutions techniques, organisationnelles et humaines. Face aux attaques adaptatives assistées par l'IA, les solutions basées sur des règles statiques sont insuffisantes.

Le principe de détection comportementale (MCO – Maintien en Conditions Opérationnelles) consiste à établir une baseline de trafic normal par apprentissage automatique, puis à identifier en temps réel tout écart statistique significatif par rapport à cette baseline. Chaque pic anormal déclenche une alerte et active les contre-mesures configurées.

Solutions techniques de protection (tableau comparatif)

Pare-feu (pfSense, Fortinet) : filtrage du trafic entrant/sortant – Protection ★★★ IDS/IPS (Snort, Suricata) : détection et blocage des comportements suspects – Protection ★★★★★ WAF (ModSecurity, F5, Imperva) : protection couche applicative HTTP – Protection ★★★★★ CDN / Reverse Proxy (Cloudflare, Akamai) : distribution de charge, masquage IP – Protection ★★★★★ Anti-DDoS Cloud (AWS Shield, Google Cloud Armor) : absorption des attaques volumétriques – Protection ★★★★★ Anycast routing : diffusion des attaques sur plusieurs datacenters mondiaux – Protection ★★★★★

Les stratégies de mitigation avancées incluent le Rate Limiting (restriction du nombre de requêtes par IP), le Blackholing/RTBH (routage vers un trou noir), le BGP Flowspec (propagation de règles de filtrage au niveau BGP) et les algorithmes de Machine Learning anti-DDoS pour adapter les règles de mitigation dynamiquement.

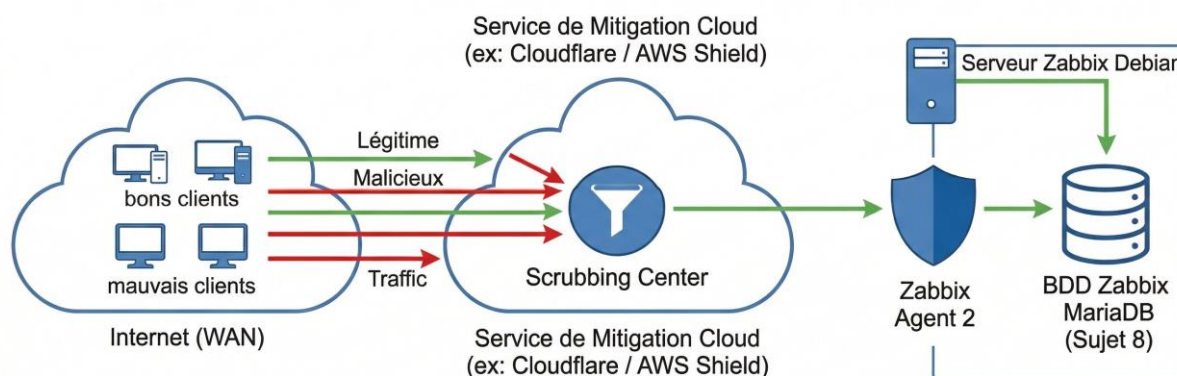


Figure 3 : Principe de la détection d'anomalies comportementales pour le MCO. Le Machine Learning établit une "Baseline" (Trafic Normal) qui permet d'identifier immédiatement les écarts statistiques correspondant à une attaque adaptative.

3.2 Vers le Zero Trust et les Scrubbing Centers

L'approche Zero Trust appliquée à la protection DDoS repose sur le principe qu'aucun trafic entrant n'est considéré comme légitime par défaut. Chaque flux doit être authentifié, validé et autorisé avant d'atteindre les serveurs de production.

Les Scrubbing Centers (centres de nettoyage) constituent la solution la plus efficace pour les attaques volumétriques massives. Proposés par des opérateurs comme Cloudflare ou AWS Shield Advanced, ces services redirigent l'intégralité du trafic entrant vers des centres de traitement spécialisés qui séparent le trafic légitime du trafic malveillant avant de le réacheminer vers la cible.

Solution		Description	Cas d'usage
Cloudflare Transit	Magic	Protection BGP anycast sur 300+ villes mondiales, atténuation automatique en <1 seconde	FAI, grandes entreprises, infrastructures critiques
AWS Advanced	Shield	Protection DDoS gérée avec accès à l'équipe DRT (DDoS Response Team) 24/7	Applications cloud AWS, e-commerce
Google Armor	Cloud	WAF + protection DDoS avec règles de sécurité adaptatives et ML intégré	Applications web, APIs REST, microservices
pfSense + Suricata		Solution open source pour PME : filtrage réseau + IDS/IPS sur site, contrôle total	PME, établissements scolaires, environnements SISR

3.3 Exemples d'attaques récentes (2025–2026)

Les années 2025 et 2026 ont été marquées par des attaques d'une ampleur sans précédent. En janvier 2025, Cloudflare a enregistré une attaque à 5,6 Tbps provenant d'un botnet de plus de 13 000 appareils IoT compromis ciblant un FAI en Asie de l'Est – atténuée en moins de 80 secondes par Magic Transit.

En mars 2025, le réseau social X (ex-Twitter) a subi une attaque multi-vecteurs revendiquée par le groupe hacktiviste Dark Storm Team, combinant floods volumétriques et attaques applicatives sur les APIs, entraînant plusieurs heures d'indisponibilité pour des millions d'utilisateurs.

Tendances 2025–2026 à surveiller

- DDoS assisté par l'IA : attaques adaptatives en temps réel contournant les défenses statiques (impact : Très élevé)
- Botnets IoT 5G : millions d'objets connectés mal sécurisés utilisés comme amplificateurs (impact : Critique)
- DDoS-as-a-Service : location de botnets sur le dark web à partir de 10\$/heure (impact : Élevé)
- Attaques multi-vecteurs : combinaison simultanée volumétrique + applicative (impact : Très élevé)
- Hausse Europe +137 % : augmentation massive enregistrée selon le Rapport Link11 2025 (impact : Critique)

4. Rôle opérationnel du technicien SISR

Le technicien SISR joue un rôle central dans la prévention et la gestion des attaques DDoS. Ses missions couvrent l'ensemble du cycle de vie de la sécurité : avant, pendant et après l'incident.

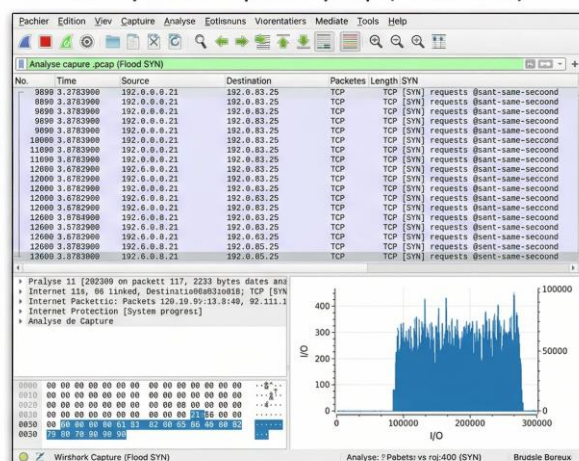
AVANT – Prévention	PENDANT – Réaction	APRÈS – Analyse
• Configurer les pare-feu, IDS/IPS et WAF • Sécuriser les équipements IoT et routeurs • Mettre en place une surveillance réseau (Zabbix, Centreon) • Planifier la capacité et le load balancing	• Détecter l'attaque via les outils de monitoring • Activer les contre-mesures (blackholing, rate limiting) • Contacter le FAI ou le service anti-DDoS cloud • Documenter l'incident en temps réel	• Analyser les logs pour comprendre les vecteurs d'attaque • Rédiger un rapport d'incident post-mortem • Mettre à jour les règles et plans de réponse • Former les équipes sur les nouvelles menaces détectées

La Figure 4 ci-dessous illustre la chaîne de réponse aux incidents telle qu'elle est mise en oeuvre dans un contexte SISR réel : depuis l'alerte visuelle sur le tableau de bord Zabbix v7.0 (Sujet 8) jusqu'à l'analyse forensique de la capture réseau .pcap par Wireshark, permettant d'identifier la signature d'un SYN Flood et de qualifier précisément le type d'attaque DDoS.

Tableau de bord MCO - Alerte DDoS (Sujet 8)



Analyse de Capture .pcap (Flood SYN)



nmap



ntopng

Figure 4 : La chaîne de réponse aux incidents pour le technicien SISR : Détection (Alerte Dashboard Zabbix v7.0 – Sujet 8) -> Analyse (Capture Wireshark .pcap d'un Flood SYN) -> Diagnostic et remédiation.

6. Analyse personnelle et conclusion

6.1 Bilan et réflexion personnelle

Cette veille technologique m'a permis de prendre conscience de l'ampleur et de l'évolution rapide de la menace DDoS. Lorsque j'ai commencé à travailler sur ce sujet, je pensais que ces attaques concernaient principalement les grandes entreprises et les organisations. La réalité est bien différente : avec la démocratisation des outils DDoS-as-a-Service, n'importe quelle entreprise, quelle que soit sa taille, peut être ciblée.

L'aspect qui m'a le plus marqué est l'utilisation croissante de l'intelligence artificielle dans les attaques DDoS. Les solutions de défense traditionnelles, basées sur des règles statiques, peinent à suivre des attaques qui s'adaptent en temps réel. Cela impose aux techniciens SISR de maîtriser non seulement les outils classiques de sécurité, mais aussi les nouvelles approches basées sur le machine learning.

L'essor de l'IoT représente également un défi majeur. Des milliards d'objets connectés, souvent peu sécurisés, constituent un réservoir quasi-inépuisable pour les botnets. Sécuriser ces équipements doit devenir une priorité, tant pour les constructeurs que pour les administrateurs réseau.

Conviction personnelle – Wesley AMAVI

En tant que futur technicien SISR, je pense que la protection contre les DDoS ne peut pas reposer uniquement sur des outils technologiques. La veille continue, la formation permanente et la capacité à anticiper les nouvelles menaces sont tout aussi essentielles. La cybersécurité est un domaine où l'on ne peut jamais se permettre de stagner.

6.2 Conclusion prospective

Les attaques DDoS représentent une menace en constante mutation, alimentée par les avancées technologiques (IA, IoT, 5G) et la professionnalisation des groupes cybercriminels. En 2025–2026, elles atteignent des niveaux records en termes de volume, de fréquence et de sophistication.

Face à cette réalité, la réponse doit être elle aussi multi-niveaux : des solutions techniques robustes et actualisées (services cloud anti-DDoS, WAF, IDS/IPS basés sur le ML), des procédures organisationnelles claires (plans de réponse aux incidents, PCA/PRA), et une formation continue des équipes techniques.

Pour le technicien SISR, cette veille technologique ne doit pas être un exercice ponctuel mais une démarche permanente. Les cybermenaces évoluent chaque jour, et seule une actualisation continue des connaissances permet de maintenir un niveau de protection efficace.

Citation de conclusion

"La cybersécurité n'est pas une destination, c'est un voyage permanent. La veille technologique est notre boussole."

Glossaire technique

Terme	Définition
DDoS	Distributed Denial of Service – Attaque par déni de service distribué visant à rendre une ressource inaccessible

Terme	Définition
SLA	Service Level Agreement – Accord contractuel définissant les garanties de disponibilité (ex : 99,9 %)
MTTR	Mean Time To Recover – Durée moyenne de rétablissement du service après un incident
Anycast	Technique de routage IP distribuant le trafic vers le serveur le plus proche géographiquement
Scrubbing Center	Centre de nettoyage du trafic : sépare le trafic légitime du trafic malveillant avant livraison
Botnet	Réseau de machines infectées contrôlées à distance par un attaquant via un serveur C&C
C&C	Command & Control – Serveur de pilotage d'un botnet émettant les ordres d'attaque
BGP Flowspec	Extension BGP permettant de propager des règles de filtrage de trafic à l'échelle inter-domaines
WAF	Web Application Firewall – Pare-feu applicatif protégeant la couche HTTP/HTTPS (couche 7 OSI)
CDN	Content Delivery Network – Réseau de distribution de contenu dispersant la charge géographiquement
Spoofing	Usurpation d'adresse IP source pour masquer l'origine réelle d'une attaque
Tbps	Térabits par seconde – Unité de mesure de la bande passante réseau (1 Tbps = 1 000 Gbps)
IDS/IPS	Intrusion Detection/Prevention System – Système de détection et blocage d'intrusions réseau